

REST API Contract Specification

Authoritative HTTP contract for MVP (R1). Implements ADD-API-Design-Standards-v4.0.pdf.

Document ID: API-REST-CONTRACT-v4.0

Version: 4.0 Production

Status: Approved for implementation

Effective date: 2026-05-24

Classification: Internal - Build team

Document control: Version 4.0 Production | Effective 2026-05-24 | Supersedes all v3.x markdown sources. Cross-references use deliverables/ paths only.

1. Base URL and protocol

- Base path: /api/v1 over HTTPS (TLS 1.2+)
- Content-Type: application/json; charset=UTF-8
- Authentication: Authorization: Bearer <JWT> except register, login, refresh, webhooks
- Errors: JSON body { code, message, traceId }; 4xx client, 5xx server
- Idempotency: Idempotency-Key header on POST /orders and payment webhooks

2. MVP endpoint catalog

Method	Path	Req IDs	Description
POST	/api/v1/auth/register	FR1	Create customer account
POST	/api/v1/auth/login	AUTH-01	Issue JWT access + refresh tokens
POST	/api/v1/auth/refresh	AUTH-01	Refresh access token
GET	/api/v1/customers/me	FR2	Get profile
PATCH	/api/v1/customers/me	FR2	Update profile
DELETE	/api/v1/customers/me	FR3	Delete account (DRRD5)
GET	/api/v1/customers/me/recommendations	FR4	Personalized recommendations
GET	/api/v1/menu/items	FR24	List menu by category
GET	/api/v1/menu/items/{itemId}	FR8	Item detail
GET	/api/v1/menu/search	FR19, FR20	Search menu (query: q, category, minPrice, maxPrice, dietary)
POST	/api/v1/cart/lines	FR8	Add to cart
PATCH	/api/v1/cart/lines/{lineId}	FR9	Update cart line
DELETE	/api/v1/cart/lines/{lineId}	FR12	Remove cart line
GET	/api/v1/cart	FR10	View cart
POST	/api/v1/cart/save	FR11	Save cart for later
POST	/api/v1/orders	FR13, FR16, FR23	Place order + payment
GET	/api/v1/orders/{orderId}	FR17	Order status
GET	/api/v1/orders	FR18	Order history
GET	/api/v1/customers/me/payment-methods	FR14	List payment methods
POST	/api/v1/customers/me/payment-methods	FR14	Add payment method
POST	/api/v1/admin/menu/items	FR5	Create menu item
PATCH	/api/v1/admin/menu/items/{itemId}	FR5	Update menu item
DELETE	/api/v1/admin/menu/items/{itemId}	FR5	Delete menu item
PATCH	/api/v1/admin/menu/items/{itemId}/availability	FR6	Set availability
POST	/api/v1/admin/promotions	FR7, FR26	Create promotion
PATCH	/api/v1/admin/promotions/{promId}	FR27	Update/deactivate promotion
GET	/api/v1/admin/reports/sales	FR21, FR22	Sales reports (date range)
GET	/api/v1/admin/reports/payments	FR25	Payment transaction reports
GET	/api/v1/admin/reports/promotions	FR29	Promotion effectiveness (compare with/without promo)
GET	/api/v1/admin/reports/reviews	FR28, FR30	Review and rating reports
POST	/api/v1/admin/reviews/{reviewId}/responses	FR30	Respond to review
POST	/api/v1/webhooks/payment	FR13, NFR10	Payment gateway webhook (HMAC)

3. Core schemas (logical)

Customer, Order, OrderLine, Item, Payment entities defined in DDD-Logical-Data-Dictionary-v4.0.pdf.

4. Security

- PCI: card data tokenized at gateway; store tokens only (NFR3, NFSR1)
- Webhook: X-Gateway-Signature HMAC-SHA256 of raw body
- Rate limit: 100 req/min per IP on auth endpoints (FR48 R2)
- RBAC: customer, staff, admin roles per SDD RBAC matrix

5. Related documents

- ADD-API-Design-Standards-v4.0.pdf
- SDD-System-Design-and-Architecture-v4.0.pdf
- RTM-Requirements-Traceability-Matrix-v4.0.xlsx